

Capstone Report: Embeddable Widget & Lead-Capture Platform

Track: Backend AI Engineering — Week 9 Capstone | **Workload:** 32h

Repository: <https://github.com/GautamKumar2005/Small-backend/tree/main/Script>

1. Executive Summary

This capstone project builds a production-grade, cross-origin Embeddable Widget and Lead-Capture Platform. Customers can define customizable widgets via an authenticated Admin API, copy a one-line `<script>` embed snippet, and place it on any external website. Because submission endpoints face untrusted browsers across the public internet, the system implements comprehensive security hardening: CORS preflight handling, boundary size checking (413 Payload Too Large), spam honeypot filters (422 Unprocessable Entity), burst rate limiting (429 Too Many Requests), a 3-provider IP-to-Geo fallback chain, and safe side-effect decoupling.

2. Key Architectural Deliverables Built

- **Authenticated Admin API:** Tenant-isolated CRUD for widgets, embed snippet generator, and live analytics.
- **CDN Config Delivery:** Serves minified JS assets and JSON config with CDN Cache-Control and ETag (304 Not Modified).
- **CORS & Boundary Validation:** Explicit OPTIONS preflight handling (204) and Content-Length boundary checks (413).
- **3-Provider Enrichment Fallback Chain:** IP to Geo resolution trying primary → secondary → fallback providers in sequence. Includes an admin toggle to simulate primary failure and verify zero-error failover.
- **Abuse Resistance:** Automatic honeypot detection (`_hp_trap`), timing heuristics (`< 1.2s`), and sliding-window rate limiting (10 requests/min).
- **Safe Side-Effect Decoupling:** Async email/webhook notification dispatch wrapped in error isolation so upstream failures never fail the lead submission (HTTP 201).

3. Automated Verification Results (10 PASSED / 0 FAILED)

Test Case	Requirement Verified	Status
1. Cache-Control & ETag	GET /api/widgets/:id/config returns cache headers	PASS (200)
2. 304 Not Modified	If-None-Match ETag header returns 304 Not Modified	PASS (304)

3. CORS Preflight	OPTIONS request returns correct ACAO origin headers	PASS (204)
4. Malformed Payload	Invalid JSON / empty body rejected with 400	PASS (400)
5. Oversized Payload	Payload > 10 KB rejected immediately with 413	PASS (413)
6. Primary Geo Enrichment	Clean lead enriched by mock-geo-primary	PASS (201)
7. Geo Fallback Chain	Primary DOWN -> seamless failover to mock-geo-secondary	PASS (201)
8. Safe Side Effects	Upstream SMTP/webhook failure never fails submission	PASS (201)
9. Honeypot Spam Filter	Hidden _hp_trap field rejected by spam filter	PASS (422)
10. Burst Rate Limiting	12 rapid requests trigger HTTP 429 Too Many Requests	PASS (429)

4. How to Run & Execute Live Demo

1. Start the platform servers (`npm start` starts port 3000 and demo site on port 3001).
2. Open the Owner Dashboard at **<http://localhost:3000/dashboard.html>**.
3. Open the Demo Customer Site at **<http://localhost:3001/customer-site.html>** to test cross-origin lead capture.
4. Use the Dashboard's **Resilience & Attack Demo** panel to trigger CORS, rate limit bursts, spam traps, and geo provider failovers live.